

HACKING WEB SERVERS LAB REPORT

BACKGROUND	
Course:	CIS 170 - Hands-On Ethical Hacking and Network Defense
Term:	Spring 2026
Instructor:	Ray Lampano, Jnr.
Section Number:	15480/15481
Student Name:	Donaven Bruce
Student ID:	[Redacted]
Submission Platform:	Canvas
Report Date:	2026-02-07
Report Version:	1.0
Lab Title:	Hacking Web Servers
Module Reference:	Hacking Web Servers
Lab Type:	Live Virtual Machine Lab
Date Completed:	2026-02-07
Time Spent:	Approximately 1 hour
ENVIRONMENT	
Platforms and Systems:	
- Primary environment: Practice Labs / Live Virtual Machine Labs controlled sandbox. - Primary systems available in the topology: PLABDC01 (Windows Server 2019 - Domain Controller), PLABDM01 (Windows Server 2019 - Domain Member), PLABWIN10 (Windows 10 - Domain Member), and PLABKALI01 (Kali 2019.2 - Linux Kali Workstation). - The work centered mainly on PLABKALI01 for exploitation and reconnaissance tools (Slowloris, Nikto, HTTPPrint, DirBuster, Skipfish, Metasploit modules) and PLABDM01/PLABWIN10 for IIS prevention tasks and enumeration. - Remote access to the virtual machines was provided through the course platform.	
Context and Constraints:	
- The module focused on web server exploitation techniques (Slowloris DoS, directory traversal, brute-forcing, reconnaissance) and prevention methods (IIS verb disabling, common hardening). - Practice Labs flagged the module as legacy content using deprecated software, so behavior could vary and some steps were best interpreted as guided sandbox demonstrations. - Windows Updates were disabled in the Practice Labs environment, so software behavior reflected a controlled legacy setup rather than a current hardened enterprise baseline. - The module aligned most closely with exam objectives 3.2 (Information Security Attack Detection) and 3.3 (Information Security Attack Prevention).	
Authorization and Scope:	
- All documented activity took place only inside approved academic systems and isolated practice-lab sandboxes. - No public IP space, real organizations, or unauthorized targets were involved. - No production infrastructure, third-party systems, or live services were contacted. - The actions documented here were performed for defensive understanding, web server attack simulation, and ethical hacking education within the course environment. - Restricted material, live credentials, and personal data are omitted or redacted from this report.	
Work Objectives:	
- Review web server vulnerabilities, common attack vectors (Slowloris, directory traversal, brute-forcing, reconnaissance), and prevention techniques. - Use Kali Linux tools (Slowloris, Nikto, HTTPPrint, DirBuster, Skipfish, Metasploit modules) on PLABKALI01 to exploit and enumerate a web server. - Apply prevention controls on IIS (disable TRACK/TRACE verbs) and review common hardening methods on Windows servers.	
Hacking Web Servers Concepts and Defensive Framing:	
- The lab identified three core phases of web server attacks: reconnaissance/enumeration, exploitation (DoS, traversal, brute-force), and post-exploitation analysis. - Attack types reviewed included Slowloris DoS, directory traversal, brute-forcing with DirBuster, web server fingerprinting (HTTPPrint, Metasploit), and reconnaissance with Skipfish. - Tools demonstrated both GUI (HTTPPrint, DirBuster) and CLI/Metasploit approaches, showing how web servers can be fingerprinted, flooded, or traversed for sensitive files. - Prevention methods reviewed included disabling dangerous HTTP verbs (TRACK/TRACE), using WAFs, proper permissions, and removing unnecessary services, reinforcing that web server defense requires both technical hardening and configuration discipline.	

TECHNICAL ANALYSIS

Web Server Exploitation and Reconnaissance on PLABKALI01:

- On PLABKALI01, Slowloris was installed via git clone and executed with `perl slowloris.pl -dns 192.168.0.10`, successfully consuming sockets and causing the bWAPP site on 192.168.0.10 to become unresponsive, demonstrating a low-bandwidth DoS.
- HTTPPrint was installed from the Intranet Hacking Tools page and run in GUI mode against 192.168.0.10 (and www.google.com for comparison), producing detailed banner, signature, and web server version fingerprinting results that were saved as HTML reports.
- DirBuster was launched with a custom wordlist (test file containing common directory names) to brute-force directories and files on `http://intranet`, successfully discovering hidden paths and generating a detailed report of found resources.
- Skipfish performed deep web application reconnaissance with `skipfish -o /root/Desktop/plab http://192.168.0.10/bWAPP`, producing a comprehensive HTML report highlighting directory listings, potential issues, and discovered endpoints.
- Metasploit Framework modules were loaded and executed: `auxiliary/scanner/http/files_dir` to locate interesting files, `auxiliary/scanner/http/options` to enumerate allowed HTTP methods, `auxiliary/scanner/http/http_version` to identify the exact server version, and `auxiliary/scanner/http/webdav_scanner` to confirm WebDAV status (disabled).

Web Server Prevention Tasks on PLABDM01/PLABWIN10:

- On PLABDM01, IIS Manager was opened, Request Filtering selected under the server node, and the HTTP Verbs tab used to explicitly deny both TRACK and TRACE verbs, preventing potential cross-site tracing and information disclosure attacks.
- Common prevention methods were reviewed and documented, including firewall placement in a DMZ, use of WAFs, disabling unnecessary services/ports, enforcing HTTPS, removing default accounts, implementing proper permissions, regular patching, and enabling auditing for failed logins and configuration changes.

KEY COMMANDS, TOOLS, AND ARTIFACTS BY SYSTEM

PLABKALI01 — Exploitation & Reconnaissance Tools:

```
git clone https://github.com/amittttt/slowloris.pl
perl slowloris.pl -dns 192.168.0.10
httpprint (GUI against 192.168.0.10)
dirbuster (with custom test wordlist)
skipfish -o /root/Desktop/plab http://192.168.0.10/bWAPP
msfconsole
use auxiliary/scanner/http/files_dir
use auxiliary/scanner/http/options
use auxiliary/scanner/http/http_version
use auxiliary/scanner/http/webdav_scanner
set RHOSTS 192.168.0.10
set THREADS 10
run
```

PLABDM01 — Prevention (IIS):

IIS Manager → Request Filtering → HTTP Verbs
Deny Verb: TRACK
Deny Verb: TRACE

Primary Tools and Artifacts Observed:

- Slowloris real-time socket consumption output showing successful DoS, HTTPPrint detailed banner and signature reports (saved as HTML), DirBuster directory brute-force results with discovered paths, Skipfish full HTML reconnaissance report highlighting issues, Metasploit module outputs (files discovered, allowed HTTP methods, server version, WebDAV status), and IIS Request Filtering configuration showing TRACK and TRACE denied.
- The most important evidence of successful web server exploitation in the lab was the Slowloris-induced unresponsiveness of the bWAPP site, directory listing via DirBuster and Skipfish, and Metasploit's confirmation of server version and available options.

DEFENSIVE MAPPING AND SUMMARY

Technique Summary:

- The completed work covered web server exploitation (Slowloris DoS, directory traversal, brute-forcing, reconnaissance with Nikto/HTTPPrint/Skipfish/Metasploit) and prevention (IIS verb disabling, common hardening practices).
- The recurring theme across the module was that web servers are high-value targets because a single misconfiguration or unpatched vulnerability can expose entire web applications.

MITRE ATT&CK Mapping:

- Initial Access: T1190 Exploit Public-Facing Application - directory traversal and Slowloris attacks directly mapped to exploiting web server weaknesses.
- Reconnaissance: T1595.002 Vulnerability Scanning / T1594 Search Victim-Owned Websites - HTTPPrint, Skipfish, and Metasploit modules demonstrated web server fingerprinting.
- Discovery: T1046 Network Service Discovery - Metasploit http_version and options modules identified running services and allowed HTTP methods.
- Impact: T1499 Endpoint Denial of Service - Slowloris demonstrated resource exhaustion of web server sockets.

Detection Opportunities:

- Partial HTTP requests (Slowloris), repeated directory traversal attempts (../ patterns), and high-volume brute-force requests (DirBuster) are strong indicators of attack.
- IDS/IPS signatures for Nikto/HTTPPrint user-agents, Metasploit module patterns, or unusual TRACE/TRACK verbs can trigger alerts.
- Web server logs showing repeated 404s on common paths, long-lived connections, or IIS verb usage should be monitored for early detection.

Defensive Controls:

- Disable dangerous HTTP verbs (TRACK, TRACE) in IIS, remove unnecessary modules, and use least-privilege accounts for web services.
- Deploy Web Application Firewalls (WAF), rate limiting, and connection timeouts to mitigate Slowloris and brute-force attacks.
- Regular patching, proper directory permissions, and disabling directory listing prevent directory traversal and information disclosure.
- Implement logging, monitoring, and input validation to detect and respond to reconnaissance and exploitation attempts early.

Completion Verification:

- Work was completed across web server exploitation (Slowloris, traversal, brute-force, reconnaissance) and prevention (IIS verb disabling and hardening).
- Completion was evidenced by successful Slowloris DoS, HTTPPrint/Skipfish reports, Metasploit module outputs, DirBuster results, and IIS TRACK/TRACE denial.
- The actual commands, tool configurations, and scan targets used in the lab are preserved directly in this report for accurate documentation and reproducibility.

Key Findings:

- 1) Web servers are prime targets because a single vulnerability (Slowloris, traversal, or misconfiguration) can lead to full compromise or denial of service.
- 2) Reconnaissance tools (HTTPPrint, Skipfish, Metasploit) quickly reveal version, options, and hidden files that feed directly into exploitation.
- 3) Simple configuration changes (disabling TRACK/TRACE, removing directory listing) provide immediate protection against common attacks.
- 4) Prevention requires layered controls - WAFs, timeouts, patching, and least-privilege - rather than relying on a single fix.
- 5) The strongest defensive takeaway was that proactive reconnaissance simulation and rapid hardening are essential to stay ahead of web server attacks.

Issues / Deviations / Notes:

- The lab used deprecated software and a legacy environment, so exact tool behavior and scan times could vary.
- Slowloris required Perl installation and Git clone.
- Some scans (Skipfish, DirBuster) were intentionally limited in duration for lab timing.

Reflection:

- This lab tied together web server reconnaissance, exploitation (DoS, traversal, brute-force), and practical prevention into a complete attack-defense workflow.
- The strongest takeaway was that web servers are dangerous because they are publicly exposed and often misconfigured, making both proactive scanning and strict hardening essential for defense.